

LEY MARCO DE CIBERSEGURIDAD N°21.663

Registro de Evaluación de Riesgos de Ciberseguridad

Normativa	Ley Marco de Ciberseguridad N°21.663
Organización	Laboratorio Clínico ACLIN Ltda.
Responsable de Ciberseguridad	Paulina Tapia Hernández (CISO)
Versión del documento	1.0
Período de cumplimiento	Octubre 2025 – Octubre 2026
Fecha de emisión	15 / 03 / 2026

Clasificación: Confidencial — Jaime Gómez Ayala — Auditor Externo de Ciberseguridad

1. OBJETIVO

Registrar formalmente la identificación, evaluación y tratamiento de los riesgos de ciberseguridad que puedan afectar la confidencialidad, integridad y disponibilidad de la información y servicios críticos del Laboratorio Clínico ACLIN Ltda..

2. METODOLOGÍA DE EVALUACIÓN

- Probabilidad: escala de 1 (muy baja) a 5 (muy alta).
- Impacto: escala de 1 (bajo) a 5 (crítico).
- Nivel de riesgo: Probabilidad × Impacto. Bajo 1–4 / Medio 5–9 / Alto 10–16 / Crítico 17–25.

3. RIESGOS IDENTIFICADOS Y EVALUADOS

Riesgo	Activo afectado	Probabilidad	Impacto	P × I	Nivel	Plan de mitigación / Responsable
IDOR en pacientes.aclin.cl	Aplicación web clínica	5 — Muy alta	5 — Crítico	25	CRÍTICO	Validación sesión + reCAPTCHA — Desarrollo/TI
MSSQL expuesto (puerto 1122)	Base de datos clínica	4 — Alta	5 — Crítico	20	CRÍTICO	Cerrar puerto + FW perimetral — TI Infraestructura
HTTP sin cifrado	pacientes.aclin.cl	4 — Alta	5 — Crítico	20	CRÍTICO	SSL/TLS + HSTS — TI Infraestructura
Phishing correo institucional	Correo institucional	4 — Alta	4 — Alto	16	Alto	Capacitación + filtros antiphishing — Área TI
Ataque ransomware	Servidor LIS	3 — Media	5 — Crítico	15	Alto	EDR + backups offline + segmentación — TI
Filtración datos de pacientes	Base de datos clínica	3 — Media	5 — Crítico	15	Alto	MFA + cifrado BD — CISO / TI
Acceso no autorizado red interna	Infraestructura de red	3 — Media	4 — Alto	12	Medio	Monitoreo accesos + segmentación — TI

Falla en reLtda.Ido automático	Sistema de backups	2 — Baja	5 — Crítico	10	Medio	Pruebas trimestrales de restauración — TI
Headers HTTP faltantes	IIS 10.0 web server	2 — Baja	3 — Moderado	6	Medio	Config. Referrer-Policy, CSP, X-Frame — TI

3 RIESGOS CRÍTICOS ACTIVOS ($P \times I \geq 17$). Conforme al Art. 23 Ley 21.663, si estos riesgos materializan en incidentes que afecten datos sensibles o servicios críticos, deben reportarse al CSIRT Nacional en las primeras 24 horas.

4. USO DEL REGISTRO

Este registro constituye evidencia documental del proceso de evaluación de riesgos y sirve como base para la Matriz de Riesgos y el Plan de Tratamiento de Riesgos de Ciberseguridad.

5. REVISIÓN

La evaluación de riesgos deberá revisarse al menos una vez al año o cuando ocurran cambios relevantes en la infraestructura tecnológica o incidentes de seguridad.

6. APROBACIÓN · VIÑA DEL MAR, CHILE

Representante Legal / CEO – ACLIN Ltda.

Marcelo Tapia Carrere

Auditor Externo · RUT 16.302.178-1

Jaime Gómez Ayala

Firma

Firma

Fecha de aprobación: ____ / ____ / 2026